

Daily Vulnerability Report - 2026-09-13

Window (UTC): 2026-09-13T00:00 to 2026-09-14T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-18 11:22:22 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
136	132	0	4	4	2	33	53	5	10

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81648	New	10.0	CRIT		0.003		The CryptoPayment Gateway WordPress plugin from 1.2.1 to 1.2.2 does not apply an authorization check on one of its AJAX endpoints, allowing unauthenticated users to invoke administrative operations, including deleting arbitrary files on the server, overwriting the payment gateway configuration and recovering stored wallet credentials in cleartext.
CVE-2026-90562	New	9.2	CRIT		0.004		LangBot before 4.10.11 generates password recovery keys with only 24 bits of entropy and applies no rate limiting to the unauthenticated reset-password endpoint. Remote attackers knowing the administrator email can exhaust the keyspace through concurrent requests to reset the admin password and gain account access.
CVE-2026-74933	New	8.8	HIGH		0.003		The GenieWords WordPress plugin from 1.5.27 to 1.5.34 does not have authorisation checks on some of its REST API and AJAX actions, and decodes stored values before printing them, allowing unauthenticated users to overwrite its configuration and inject arbitrary web scripts that execute on every front-end page.
CVE-2026-85129	New	8.8	HIGH		0.003		The Hoo Companion WordPress plugin 1.0.2 does not have any authorisation or validation checks in one of its import features, and does not sanitise the data submitted to it before storing it as the active theme's settings, allowing unauthenticated attackers to inject arbitrary web scripts which will execute for anyone viewing the site, including administrators. The same reque...
CVE-2026-88793	New	8.8	HIGH		0.003		The YouTube Embed WordPress plugin from 10.0 to 10.3 does not perform any authorisation check on one of its AJAX actions, relying only on a nonce it prints on every front-end page, and does not escape the stored data before rendering it, allowing unauthenticated attackers to store arbitrary web scripts which will execute in the session of any user viewing the affected conten...
CVE-2026-90770	New	8.8	HIGH		0.007		Spug through 3.4.0 contains a remote code execution vulnerability in the ping_check function that interpolates user-supplied monitor addresses directly into shell commands without validation. Authenticated users with monitor permissions can inject shell metacharacters via the /monitor/run_test/ endpoint to execute arbitrary commands as the Spug process user.
CVE-2026-90561	New	8.7	HIGH		0.002		Strapi versions 4.x through 4.26.2 and 5.x before 5.48.1 contain a stored cross-site scripting vulnerability in the content manager WYSIWYG preview component that fails to strip script tags from rich text. An Author-role user can store malicious script tags in rich text fields that execute in an Editor or Super Admin's session when the preview pane is expanded, enabling acco...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90668	New	8.7	HIGH		0.003		The webserver in UnreallRCd 6.0.5 through 6.2.6 before 6.2.7 does not limit the number of HTTP request headers, which allows remote attackers to cause a denial of service (memory consumption and unresponsive server) via an HTTP request with an unlimited number of headers, if a websocket or JSON-RPC listener is enabled (disabled by default).
CVE-2026-90774	New	8.7	HIGH		0.004		rustypaste before 0.18.1 validates the destination path before applying the optional custom filename HTTP header, allowing attackers to bypass directory-escape checks. Attackers can supply path traversal sequences in the filename header to write files outside the configured upload directory to arbitrary locations.
CVE-2026-90776	New	8.7	HIGH		0.005		Nodemailer versions 9.1.0 through 10.0.4 contain a quadratic time complexity vulnerability in the addressparser component when parsing email addresses with RFC 5322 comments. Attackers can craft malicious email headers with comment-separated atoms to consume excessive CPU and block the Node.js event loop for several seconds, causing denial of service.
CVE-2026-90777	New	8.7	HIGH		0.005		ESPnet before 202609 deserializes pretrained model checkpoints using torch.load with weights_only=False, allowing arbitrary code execution from attacker-supplied files. Attackers can craft malicious checkpoint files that execute code during deserialization when loaded through the initialization or fine-tuning path.
CVE-2026-90778	New	8.7	HIGH		0.006		SIPp through 3.7.7 contains a buffer overflow vulnerability in get_peer_tag() function when processing SIP To headers with tag parameters of 2049 bytes or more. Unauthenticated remote attackers can send crafted SIP messages with oversized tag parameters to overflow the static buffer and crash the process.
CVE-2026-90779	New	8.7	HIGH		0.006		SIPp through 3.7.7 contains a stack buffer overflow vulnerability in createAuthHeader() when processing SIP authentication challenges with oversized algorithm parameters. A malicious SIP server can send a crafted 401 or 407 challenge to corrupt the stack and crash the client process.
CVE-2026-90768	New	8.6	HIGH		0.002		CAPEv2 through commit 471ee4b fails to validate task ownership in REST API endpoints, allowing authenticated users to read and delete analyses submitted by other users. Attackers can enumerate all tasks in the system and delete arbitrary analyses by sending requests to task view and delete endpoints without ownership verification.
CVE-2026-90493	New	8.5	HIGH		0.001		A vulnerability was detected in Tonec Internet Download Manager up to 6.42 Build 63 on Windows. The impacted element is an unknown function of the file idmwfp.sys of the component Kernel Driver. The manipulation results in improper access controls. Attacking locally is a requirement. Internet Download Manager for Windows up to and including 6.42 Build 63 installs idmwfp.sys,...
CVE-2026-90783	New	8.5	HIGH		0.001		MKVToolNix through 101.0 contains a heap buffer overflow in the bundled avilib library's ODM superindex parser due to integer wraparound in 32-bit arithmetic. Attackers can craft a malicious AVI file with oversized entry counts that cause an undersized heap allocation, allowing a heap buffer overflow when the file is parsed with mkvmerge.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90769	New	8.3	HIGH		0.003		Open Notebook before 1.11.0 fails to validate the URL parameter in POST /api/sources endpoint, allowing authenticated users to perform server-side requests to internal services. Attackers can supply arbitrary URLs to read cloud metadata, internal network services, and localhost-bound services through the application server's direct HTTP requests.
CVE-2026-90772	New	8.3	HIGH		0.002		Amundsen frontend through 4.3.0 renders table, dashboard, and feature descriptions with dangerouslySetInnerHTML without HTML sanitization in ResourceListItem components. Attackers can inject malicious markup like img elements with onerror handlers into descriptions via the metadata service or Elasticsearch, executing JavaScript in every user's browser that views search results.
CVE-2026-37008	New	8.1	HIGH		0.001		CrewAI before fb2323b offers a Python blacklist approach that operates at the wrong level of abstraction, a different vulnerability than CVE-2026-2275. Import-time blocking of module names does not address the availability of Python's complete object graph. For example, calling ctypes.CDLL(None) loads the C library without relying in any import statements. In other words, a ...
CVE-2026-90651	New	8.1	HIGH		0.002		Socket Firewall (socketdev/socket-registry-firewall) in registry mode before 2.0.0 does not verify upstream TLS certificates by default. When the api_ssl_verify and upstream_ssl_verify configuration keys are omitted from socket.yml, the generated configuration sets SOCKET_API_SSL_VERIFY='false' and UPSTREAM_SSL_VERIFY='false', and the OpenResty/Lua HTTP client used for outbo...
CVE-2026-29811	New	7.7	HIGH		0.003		CyberPanel before 2.4.4 attempts to detect an "alais" domain (i.e., a second domain that serves the same content as a primary domain; normally spelled "alias") via an ORM query filter rather than a Python "if" statement.
CVE-2026-15891	New	7.5	HIGH		0.003		The MQTT-SN client keepalive handler process_ping() in subsys/net/lib/mqtt_sn/mqtt_sn.c removes the gateway record after PINGREQ retries are exhausted. It invoked SYS_SLIST_PEEK_HEAD_CONTAINER(&client->gateways, gw, next) but discarded the result. That macro is a pure expression that does not assign to gw, so gw retained its NULL initializer regardless of the list contents. ...
CVE-2026-86406	New	7.5	HIGH		0.002		The User Registration & Membership WordPress plugin before 5.2.8 does not check the capability of the user making a membership purchase, and does not validate the payment method or the plan submitted with it, allowing any authenticated user such as a subscriber to be granted the WordPress role attached to a paid plan without paying for it. Where the site owner has mapped a ...
CVE-2026-88802	New	7.5	HIGH		0.002		The MDJM Event Management WordPress plugin before 1.7.8.5 and the Mobile Events Manager WordPress plugin through 1.4.8.3 do not check a capability, a nonce or the type of the record before permanently deleting the post identified in a request to their playlist entry removal, allowing unauthenticated attackers to destroy arbitrary posts, pages and media attachments, bypassing...
CVE-2026-89080	New	7.5	HIGH		0.002		The Really Simple Security WordPress plugin before 9.8.1 does not prevent an unauthenticated request from resetting an account's completed email two-factor enrolment, allowing an attacker who already knows the account's password to bypass the second factor and obtain that user's session, up to administrator.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90678	New	7.5	HIGH		0.005		An issue was discovered in HAProxy 3.3.0 through 3.4.4 and in 3.5-dev1 through 3.5-dev5. Exploitation requires an HTTP/3 frontend: HAProxy must be built with QUIC support and configured with a QUIC bind listener, and the affected traffic must reach a backend over HTTP/1.1 using chunked transfer coding on a reused connection. Under those conditions, when an HTTP/3 request car...
CVE-2026-90780	New	7.5	HIGH		0.006		SIPp through 3.7.7 contains a buffer overflow vulnerability in the get_header() function in src/sip_parser.cpp when processing SIP messages with header content exceeding 20,490 bytes. Unauthenticated remote attackers can send crafted SIP messages with oversized headers to overflow the static buffer and crash the process.
CVE-2026-36453	New	7.4	HIGH		0.002		Rhymix before 2.1.31 allows insecure direct object reference, aka RVE-2026-1. Arbitrary files can be accessed via extra variables.
CVE-2026-90504	New	7.3	HIGH		0.006		A vulnerability has been found in vvbnn00 WARP-Clash-API up to c7bf2360073959861219b422e51ae86411051b46. The impacted element is the function authorized. The manipulation of the argument SECRET_KEY leads to missing authentication. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used. Continuous delivery with rolling releases is ...
CVE-2026-90509	New	7.3	HIGH		0.003		A weakness has been identified in dromara orion-visor up to 2.5.7. Affected by this issue is the function ExposeApiAspect.beforeExposeApi of the file ExposeApiAspect.java. Executing a manipulation can lead to hard-coded credentials. The attack can be executed remotely. The exploit has been made available to the public and could be used for attacks. The project was informed o...
CVE-2026-90515	New	7.3	HIGH		0.003		A vulnerability was determined in SourceCodester School Registration and Fee System 1.0. The impacted element is an unknown function of the file /bilal/normal/delete_stud.php. Executing a manipulation of the argument selector[] can lead to sql injection. The attack can be launched remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-80071	New	7.2	HIGH		0.003		The User Registration & Membership WordPress plugin before 5.2.8 does not properly restrict who may author a membership plan or validate the plan a user attaches to their own account, allowing authenticated users with Author-level access and above to assign themselves an arbitrary role and escalate their privileges to Administrator.
CVE-2026-90648	New	7.1	HIGH		0.002		wasm2c in WebAssembly wabt through 1.0.41 allows sandbox escape in some situations that primarily involve 32-bit platforms, aka a "table flip" attack. It does not check the return value of calloc() in wasm_rt_allocate_funcref_table() (wasm2c/wasm-rt-impl-tableops.inc). When the funcref table allocation fails, table->data is left NULL while table->size keeps the guest-declare...
CVE-2026-90767	New	7.1	HIGH		0.002		Froxlор before 2.3.12 fails to properly validate multi-line SSH public keys in the SshKeys::add() endpoint, allowing customers to inject arbitrary lines into authorized_keys files. Attackers can inject malicious SSH key entries with option directives to gain persistent unauthorized access that survives key deletion and SSH access revocation.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90513	New	6.9	MEDI		0.004		A flaw has been found in simalexan api-lambda-send-email-ses up to bda6869aa81371d1e872242e74fe7d953edb818d. This issue affects the function SES.sendEmail of the file template.yml of the component API Gateway Endpoint. This manipulation of the argument toEmails/ccEmails/replyToEmails/subject/message causes missing authentication. It is possible to initiate the attack remotel...
CVE-2026-90593	New	6.9	MEDI		0.004		A vulnerability was determined in embedded-graphics up to 0.8.2. This affects the function ImageRaw::draw_sub_image of the file src/image/image_raw.rs. Executing a manipulation of the argument width can lead to integer overflow. The attack may be launched remotely. The project was informed of the problem early through an issue report but has not responded yet.
CVE-2026-90596	New	6.9	MEDI		0.003		A weakness has been identified in embedded-graphics up to 0.8.2 on 32-bit. Impacted is the function ImageRaw::new/bytes_per_row of the file src/image/image_raw.rs. This manipulation causes integer overflow. The attack is possible to be carried out remotely. Upgrading the affected component is recommended. The project was informed of the problem early through an issue report ...
CVE-2026-90601	New	6.9	MEDI		0.004		A vulnerability was found in getzep graphiti up to 0.30.2. Affected is an unknown function of the file server/graph_service/main.py of the component REST API. The manipulation results in improper authentication. The attack can be launched remotely. The pull request to fix this issue awaits acceptance.
CVE-2026-90603	New	6.9	MEDI		0.005		A vulnerability was identified in Anil-matcha Open-Generative-AI up to 1.0.11/2.0.0. Affected by this issue is some unknown functionality of the file /api/upload-binary of the component S3 Upload. Such manipulation of the argument x-proxy-target-url leads to unrestricted upload. The attack may be launched remotely. The name of the patch is f013270957f75e439eaf97eb2a93dec32a...
CVE-2026-90775	New	6.5	MEDI		0.003		PostGIS address_standardizer through 3.7.0 fails to validate the Weight parameter from caller-supplied rules tables before using it as an array index. Attackers can craft malicious rule rows with out-of-range Weight values to trigger out-of-bounds reads in the load_value array, causing the PostgreSQL backend process to crash and terminate all cluster sessions.
CVE-2025-70819	New	6.3	MEDI		0.001		Zettlab D6 Ultra before 1.7.0 allows mounting /etc/passwd and /etc/shadow in a container via ".." manipulations such as volumes: - .././.././.././etc:/h_etc:rw in a compose file.
CVE-2026-90520	New	6.3	MEDI		0.004		A vulnerability has been found in jaychouchannel Tourism-Management-System up to 84d8ec384f669df3985293dab293bb7b477efa64. This vulnerability affects unknown code of the file AuthorizationInterceptor.java of the component Authorization Interceptor. The manipulation leads to improper authorization. It is possible to initiate the attack remotely. The exploit has been disclosed...
CVE-2026-90525	New	6.3	MEDI		0.003		A weakness has been identified in itsourcecode Sales and Inventory System 1.0. This affects an unknown function of the file /pages/cust_pos_trans.php. Executing a manipulation of the argument firstname can lead to sql injection. The attack may be launched remotely. The exploit has been made available to the public and could be used for attacks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90771	New	6.3	MEDI		0.003		joi before versions 17.13.8 and 18.2.9 contains a prototype pollution vulnerability in the messages compilation function that accepts __proto__ as an error code. Attackers can supply __proto__ keys in custom messages to replace the returned object's prototype, breaking downstream code relying on Object.prototype methods.
CVE-2026-90782	New	6.0	MEDI		0.003		S2OPC through 1.7.3 contains a null pointer dereference in msg_subscription_publish_bs_alloc_notification_message_items() where a failed allocation for DataChangeNotification is overwritten by a successful allocation for EventNotificationList. Attackers can trigger heap allocation failures on sessions with both data-change and event notifications to cause the server process...
CVE-2026-36989	New	5.8	MEDI		0.002		A SQL Injection vulnerability exists in LuxSoft LuxCal through 5.3.4L via rssfeed.php and common/retrieve.php.
CVE-2026-90495	New	5.5	MEDI		0.003		A vulnerability has been found in Fengoffice Feng Office up to 3.11.13.11. This impacts the function Contacts::instance->findAll of the file application/models/CompanyWebsite.class.php of the component Legacy API. Such manipulation of the argument auth leads to sql injection. The attack can be launched remotely. The exploit has been disclosed to the public and may be used. T...
CVE-2026-90498	New	5.5	MEDI		0.003		A vulnerability was identified in lenve vhr 1.0-SNAPSHOT. Affected by this issue is some unknown functionality of the file vhr.sql. The manipulation leads to use of default credentials. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-90510	New	5.5	MEDI		0.003		A security vulnerability has been detected in dromara orion-visor up to 2.5.7. This affects the function HostKeyServiceImpl.encryptKey of the file orion-visor-modules/orion-visor-module-asset/orion-visor-module-asset-service/src/main/java/org/dromara/visor/module/asset/service/impl/HostKeyServiceImpl.java. The manipulation leads to use of hard-coded cryptographic key . The ...
CVE-2026-90514	New	5.5	MEDI		0.003		A vulnerability has been found in SourceCodester School Registration and Fee System 1.0. Impacted is an unknown function of the file /bilal/normal/save_stud.php. Such manipulation of the argument Status leads to sql injection. It is possible to launch the attack remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-90516	New	5.5	MEDI		0.004		A vulnerability was found in SourceCodester School Registration and Fee System 1.0. The affected element is an unknown function of the file /bilal/normal/pay_report.php. Performing a manipulation of the argument period results in sql injection. The attack can be initiated remotely. The exploit has been made public and could be used.
CVE-2026-90517	New	5.5	MEDI		0.003		A vulnerability was identified in PHPGurukul Bank Locker Management System 1.0. This affects an unknown function of the file /blms/view-assign-locker.php. The manipulation of the argument ltid leads to authorization bypass. The attack may be initiated remotely. The exploit is publicly available and might be used.
CVE-2026-90522	New	5.5	MEDI		0.005		A vulnerability was determined in jaychouchannel Tourism-Management-System up to d984d172dceca907f8b447efbdb06dc233f7938d. Impacted is the function resetPass of the file UsersController.java of the component Password Recovery. This manipulation causes weak password recovery. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Co...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90523	New	5.5	MEDI		0.005		A vulnerability was identified in jaychouchannel Tourism-Management-System up to 229956e20dbd4a80eeff14535e44d3099502af09. The affected element is an unknown function of the file travel/src/main/java/com/controller/UsersController.java of the component User Register Endpoint. Such manipulation of the argument UsersEntity leads to improper privilege management. The attack can...
CVE-2026-90524	New	5.5	MEDI		0.007		A security flaw has been discovered in jaychouchannel Tourism-Management-System up to 229956e20dbd4a80eeff14535e44d3099502af09. The impacted element is an unknown function of the component Update Endpoint. Performing a manipulation results in missing authentication. The attack may be initiated remotely. The exploit has been released to the public and may be used for attacks....
CVE-2026-90526	New	5.5	MEDI		0.004		A security vulnerability has been detected in SourceCodester School Registration and Fee System 1.0. This impacts an unknown function of the file /bital/save_class.php. The manipulation of the argument Category leads to sql injection. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used.
CVE-2026-90565	New	5.5	MEDI		0.005		A security flaw has been discovered in Rizwan17 inventory-management-system up to bfe78a330d01bb26b9daec5dc9ecd5c77900e03f. Affected is an unknown function of the file dashboard.php. Performing a manipulation of the argument userid results in improper access controls. It is possible to initiate the attack remotely. The exploit has been released to the public and may be used ...
CVE-2026-90566	New	5.5	MEDI		0.005		A weakness has been identified in Rizwan17 inventory-management-system up to bfe78a330d01bb26b9daec5dc9ecd5c77900e03f. Affected by this vulnerability is the function createUserAccount of the file register.php of the component Registration Handler. Executing a manipulation of the argument usertype can lead to improper authorization. It is possible to launch the attack remotel...
CVE-2026-90579	New	5.5	MEDI		0.004		A vulnerability has been found in cheshire-cat-ai Cheshire Cat AI up to 1.9.2. This affects the function _authorize_http_key of the file core/cat/factory/custom_auth_handler.py. The manipulation of the argument user_id leads to missing authentication. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used. The project was informed ...
CVE-2026-90582	New	5.5	MEDI		0.004		A vulnerability was identified in evanchiu serverless-todo 1.0.3/2.0.0. Impacted is the function saveTodos of the file src/index.js of the component API Todo Endpoint. Such manipulation of the argument event.body leads to resource consumption. The attack can be executed remotely. The exploit is publicly available and might be used. The project was informed of the problem ear...
CVE-2026-90584	New	5.5	MEDI		0.004		A weakness has been identified in TooTallNate Java-WebSocket up to 1.6.1. The impacted element is the function processFrameContinuousAndNonFin of the file Draft_6455.java of the component Fragmentation Handler. Executing a manipulation can lead to allocation of resources. The attack may be performed from remote. The exploit has been made available to the public and could be ...
CVE-2026-88764	New	5.4	MEDI		0.001		The Simple Membership WordPress plugin before 4.7.8 does not validate that the membership level supplied in a PayPal payment notification matches the level configured for the paid payment button, allowing members to pay for a lower-priced membership while being granted a higher, more privileged membership level.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90499	New	5.4	MEDI		0.003		A security flaw has been discovered in lenve vhr 1.0-SNAPSHOT. This affects the function HrInfoController.updatePass of the file /hr/pass of the component Password Update Handler. The manipulation of the argument hrid results in improper authorization. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks. The vendor was...
CVE-2026-15892	New	5.3	MEDI		0.003		The mcumgr SMP settings-management group handlers settings_mgmt_read(), settings_mgmt_write(), and settings_mgmt_delete() in subsys/mgmt/mcumgr/grp/settings_mgmt/src/settings_mgmt.c allocate a key_name buffer (and, for read, a data buffer) via k_malloc() when CONFIG_MCUMGR_GRP_SETTINGS_BUFFER_TYPE_HEAP is enabled, relying on the end: label to k_free() them. When CONFIG_MCUMG...
CVE-2026-77773	New	5.3	MEDI		0.002		The Contact Form to Chat Apps Click to Chat to Order WordPress plugin before 2.15.8 does not perform any capability, nonce or session check on one of its public AJAX actions, allowing unauthenticated users to read the submitted entries of any form created with a supported third-party form Contact Form to Chat Apps Click to Chat to Order WordPress plugin before 2.15.8.
CVE-2026-88995	New	5.3	MEDI		0.002		The Bookit — Booking & Appointment Calendar WordPress plugin before 2.6.0.1 does not properly restrict the data returned by an availability-check request, allowing unauthenticated users to retrieve other customers' appointment details, including free-text booking comments and contact information.
CVE-2026-90494	New	5.3	MEDI		0.005		A flaw has been found in restify node-restify up to 12.0.0. This affects the function serveStatic in the library /lib/plugins/static.js. This manipulation causes path traversal. The attack can be initiated remotely. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-90527	New	5.3	MEDI		0.003		A vulnerability was detected in quequnlong shiyi-blog up to 1.2.1. Affected is an unknown function of the file blog-admin/src/views/message/message/index.vue of the component Add Message API. The manipulation of the argument body.content results in cross site scripting. The attack can be executed remotely. The project was informed of the problem early through an issue report...
CVE-2026-90571	New	5.3	MEDI		0.003		A vulnerability was found in Exrick xmall up to 19e7917d5ed3bd2a2421a3a246ad494c133ba94c. Impacted is an unknown function of the file xmall-manager-web/src/main/webapp/WEB-INF/jsp/order-print.jsp of the component Order Printing. Performing a manipulation results in cross site scripting. Remote exploitation of the attack is possible. This product follows a rolling release app...
CVE-2026-90583	New	5.3	MEDI		0.003		A security flaw has been discovered in kagisearch smallweb up to 0ecb9c48edbf98dc7e934b54fbac43869e64b4cf. The affected element is the function index of the file app/sw.py of the component Query String Rendering. Performing a manipulation of the argument qs results in cross site scripting. The attack is possible to be carried out remotely. This product adopts a rolling relea...
CVE-2026-90528	New	5.1	MEDI		0.002		A flaw has been found in TDuckApp tduck-platform up to 5.3. Affected by this vulnerability is an unknown functionality of the file tduck-front/src/views/form/write/index.vue of the component Form Write View. This manipulation of the argument submitShowCustomPageContent causes cross site scripting. The attack is possible to be carried out remotely. The project was informed of...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90529	New	5.1	MEDI		0.002		A vulnerability has been found in DataEase up to 2.10.25/2.10.26. Affected by this issue is the function buildTooltip of the file core/core-frontend/src/views/chart/components/js/panel/charts/map/symbolic-map.ts of the component Symbolic Map. Such manipulation of the argument canvasViewInfo[*].customAttr.tooltip.backgroundColor leads to cross site scripting. The attack may b...
CVE-2026-90563	New	5.1	MEDI		0.002		A vulnerability was determined in maliangnansheng bbs-springboot 3.0.0. This affects the function utils.toToc of the file ArticleController.java. This manipulation causes cross site scripting. The attack is possible to be carried out remotely.
CVE-2026-90564	New	5.1	MEDI		0.002		A vulnerability was identified in quequnlong shiyi-blog 1.0.0-1.2.1. This impacts the function SysChatMsgMapper.getChatMsgList of the file blog-web/src/views/chat/index.vue of the component chat sendMsg Endpoint. Such manipulation of the argument chat_msg leads to cross site scripting. The attack may be performed from remote. The project was informed of the problem early thr...
CVE-2026-90567	New	5.1	MEDI		0.003		A security vulnerability has been detected in quequnlong shiyi-blog up to 1.2.1. Affected by this issue is the function highlightKeyword of the file blog-web/src/components/Search/index.vue of the component Search. The manipulation of the argument title/summary leads to cross site scripting. The attack can be initiated remotely. The project was informed of the problem early ...
CVE-2026-90568	New	5.1	MEDI		0.003		A vulnerability was detected in moxi624 Mogu Blog v2 up to 5.2. This affects the function BlogSortServiceImpl.addBlogSort of the file mogu_web/src/main/resources/templates/info.ftl of the component blogSort Endpoint. The manipulation of the argument sortName results in cross site scripting. The attack can be launched remotely. The project was informed of the problem early th...
CVE-2026-90602	New	5.1	MEDI		0.003		A vulnerability was determined in Anil-matcha Open-Generative-AI up to 1.0.11/2.0.0. Affected by this vulnerability is the function renderHistory of the file ImageStudio.js of the component Studio Components. This manipulation causes cross site scripting. The attack may be initiated remotely. The pull request to fix this issue awaits acceptance.
CVE-2020-15875	New	5.0	MEDI		0.003		An issue was discovered in LibreNMS 1.65. A remote authenticated attacker with normal privileges can extract all the information from the LibreNMS database via a SQL injection in the searchPhrase parameter in the /ajax_table.php API endpoint. This affects as-selection.inc.php, edit-ports.inc.php, alertlog-stats.inc.php, alerts.inc.php, eventlog.inc.php, inventory.inc.php, ix...
CVE-2026-90569	New	4.8	MEDI		0.003		A flaw has been found in linlinjava litemall 1.5.0/1.6.0/1.7.0/1.8.0. This vulnerability affects the function AdminTopicController.validate of the file litemall-vue/src/views/items/topic/index.vue of the component Admin Topic Handler. This manipulation causes cross site scripting. The attack may be initiated remotely. The project was informed of the problem early through an ...
CVE-2026-90570	New	4.8	MEDI		0.003		A vulnerability has been found in linlinjava litemall 1.4.0/1.5.0/1.6.0/1.7.0/1.8.0. This issue affects the function AdminGoodsService.validate of the file litemall-vue/src/views/items/detail/index.vue of the component Product Detail. Such manipulation of the argument detail leads to cross site scripting. The attack may be launched remotely. The project was informed of the p...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90781	New	4.8	MEDI		0.002		alsa-lib through 1.2.16.1 contains a stack buffer overflow in the __snd_ctl_ascii_elem_id_parse() function that writes one byte past a 64-byte buffer when parsing a name= field with 64 or more characters. Attackers can supply a long control-element identifier string through saved state files or command-line arguments to overwrite adjacent stack memory and crash the calling p...
CVE-2026-80072	New	4.7	MEDI		0.002		The User Registration & Membership WordPress plugin before 5.2.8 does not validate the destination of a post-login redirect before redirecting, allowing unauthenticated attackers to redirect visitors to an arbitrary external URL, which can be abused for phishing.
CVE-2026-29810	New	4.3	MEDI		0.003		CyberPanel before 2.4.4 omits a "return 0" that is required by the business logic.
CVE-2026-29812	New	4.3	MEDI		0.002		CyberPanel before 2.4.4 has no logging for actions that could potentially manipulate the child domains list.
CVE-2026-89050	New	4.3	MEDI		0.001		The Quads Ads Manager for Google AdSense WordPress plugin before 3.0.5 does not verify payment completion with the configured payment gateway before marking an ad-selling order as paid, allowing users who can place an order to obtain a paid ad placement without payment.
CVE-2026-90679	New	4.3	MEDI		0.002		Forgejo 13.0.0 through 16.0.4, when "[federation] ENABLED = true" is set, has a spoofing issue that affects identity integrity but does not allow account takeover or content modification. It does not verify that the HTTP Signature on an incoming ActivityPub activity was produced by the key belonging to the actor named in the activity body. The signature verification in route...
CVE-2026-88912	New	4.2	MEDI		0.001		The rtMedia for WordPress, BuddyPress and bbPress WordPress plugin before 4.7.12 does not check ownership before changing the privacy level of an activity and its attached media, relying only on a nonce shared with every logged-in user, allowing users with a subscriber-level account or above to make another user's private activity public or hide it.
CVE-2026-86407	New	3.7	LOW		0.002		The User Registration & Membership WordPress plugin before 5.2.8 does not verify that the visitor requesting its membership confirmation page owns the account named in the request, nor that any registration or purchase has taken place, allowing unauthenticated users to retrieve another user's email address, profile fields, role and membership order details. Exploitation req...
CVE-2025-70820	New	3.5	LOW		0.002		Zettlab D6 Ultra before 1.7.0 allows absolute path traversal to reach folders other than the personal folder.
CVE-2026-90489	New	3.5	LOW		0.002		A vulnerability was identified in Xuxueli xxl-job up to 3.5.0. This vulnerability affects unknown code of the file /jobinfo/insert. Such manipulation of the argument name/author leads to cross site scripting. The attack can be executed remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond in an...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-35867	New	3.1	LOW		0.005		A Command Injection vulnerability exists in the bs_SetLimitCli_info function within the libshare.so library of the LB-LINK router AC1900_AZ2 V1.0.2 via shell metacharacters, if the device is deployed in a scenario where an actor is able to make a "POST /goform/set_LimitClient_cfg" call but does not already have administrative access to the device.
CVE-2025-45480	New	3.0	LOW		0.002		Floodlight 71fe8a7 allows disruption of host communication via link spoofing. A port is misclassified as a non-boundary.
CVE-2026-38332	New	2.9	LOW		0.001		TinyEXIF before 1.1.0 has a heap-based buffer over-read in EntryParser::Fetch methods reachable via a crafted SubjectArea length.
CVE-2026-52296	New	2.9	LOW		0.002		FFmpeg before 9.0 has an out-of-bounds read because of missing required padding in WMA extradata allocation paths in libavcodec/wmaenc.c.
CVE-2026-52297	New	2.9	LOW		0.001		FFmpeg before 9.0 has an out-of-bounds read because there is insufficiently padded extradata in the MOV parsing path in mov_read_iacb in libavformat/mov.c.
CVE-2026-90575	New	2.9	LOW		0.005		A weakness has been identified in PHPGurukul Small CRM 4.0. This impacts the function unserialize of the file /crm/login.php of the component Login Success Handler. This manipulation of the argument geopluginURL causes deserialization. It is possible to initiate the attack remotely. The complexity of an attack is rather high. The exploitability is said to be difficult. The e...
CVE-2026-90773	New	2.4	LOW		0.001		procs through 0.14.12 fails to sanitize escape sequences in process command lines before displaying them in the Command column. Local attackers can execute processes with malicious ANSI or OSC escape sequences in their command line arguments, which are written unmodified to other users' terminals for interpretation by terminal emulators.
CVE-2026-90488	New	2.1	LOW		0.002		A vulnerability was determined in Xuxueli xxl-job up to 3.4.2. This affects the function GroovyClassLoader.parseClass of the file xxl-job-core/src/main/java/com/xxl/job/core/glue/GlueFactory.java. This manipulation causes code injection. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early ...
CVE-2026-90490	New	2.1	LOW		0.004		A security flaw has been discovered in lenve vhr 1.0-SNAPSHOT. This issue affects some unknown processing of the component MailReceiver. Performing a manipulation results in deserialization. The attack is possible to be carried out remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early about this disclosure but did n...
CVE-2026-90491	New	2.1	LOW		0.002		A weakness has been identified in sanjeviraui gsubs up to 1.0.3. Impacted is the function showQuerySuccessPage of the file renderer/index.js of the component Electron. Executing a manipulation of the argument filename can lead to code injection. The attack may be performed from remote. The exploit has been made available to the public and could be used for attacks. The vendor...
CVE-2026-90492	New	2.1	LOW		0.015		A security vulnerability has been detected in webgjc web_robot 2.4.0/2.5.0/2.8.0. The affected element is the function controller_listen/controller_recover of the file py/web.py. The manipulation of the argument case_name leads to os command injection. It is possible to initiate the attack remotely. The exploit has been disclosed publicly and may be used. The vendor was cont...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90500	New	2.1	LOW		0.002		A weakness has been identified in lenve vhr 1.0-SNAPSHOT. This vulnerability affects the function FastDFSUtils.upload of the file /hr/userface of the component Avatar Upload. This manipulation of the argument File causes unrestricted upload. The attack is possible to be carried out remotely. The exploit has been made available to the public and could be used for attacks. The...
CVE-2026-90501	New	2.1	LOW		0.002		A security vulnerability has been detected in lenve vhr 1.0-SNAPSHOT. This issue affects the function HrInfoController.updateHr of the file HrMapper.xml. Such manipulation of the argument Password leads to improper privilege management. The attack may be performed from remote. The exploit has been disclosed publicly and may be used. The vendor was contacted early about this ...
CVE-2026-90507	New	2.1	LOW		0.004		A vulnerability was identified in vvbnn00 WARP-Clash-API up to c7bf2360073959861219b422e51ae86411051b46. Affected is the function get_surge_subscription of the file services/subscription.py of the component Subscription Handler. Such manipulation of the argument key leads to improper access controls. The attack may be launched remotely. The exploit is publicly available and...
CVE-2026-90511	New	2.1	LOW		0.002		A vulnerability was detected in GongShengyue OnlineBooks up to dfc5eacc08d3b0396c266049548618f6fb9587ea. This vulnerability affects unknown code of the file src/cn/ylcto/book/servlet/BooksServlet.java of the component listSplit Interface. The manipulation of the argument column results in sql injection. The attack may be performed from remote. The exploit is now public and m...
CVE-2026-90518	New	2.1	LOW		0.002		A security flaw has been discovered in PHPGurukul Bank Locker Management System 1.0. This impacts an unknown function of the file sidebar.php. The manipulation of the argument UserType results in improper access controls. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks.
CVE-2026-90519	New	2.1	LOW		0.002		A weakness has been identified in PHPGurukul Bank Locker Management System 1.0. Affected is an unknown function of the file /blms/banker/add-locker-form.php. This manipulation of the argument addressproof causes unrestricted upload. Remote exploitation of the attack is possible. The exploit has been made available to the public and could be used for attacks.
CVE-2026-90521	New	2.1	LOW		0.004		A vulnerability was found in jaychouchannel Tourism-Management-System up to 8122bf020d91199eddf3ee02d1632a70a9a132. This issue affects some unknown processing of the file MenpiaodingdanController.java of the component CRUD. The manipulation of the argument ID results in authorization bypass. It is possible to launch the attack remotely. The exploit has been made public and...
CVE-2026-90574	New	2.1	LOW		0.003		A security flaw has been discovered in itsourcecode Sales and Inventory System 1.0. This affects an unknown function of the file /pages/emp_transac.php?action=add. The manipulation of the argument firstname results in sql injection. The attack may be performed from remote. The exploit has been released to the public and may be used for attacks.
CVE-2026-90580	New	2.1	LOW		0.002	flowiseai:flowise	A vulnerability was found in FlowiseAI Flowise up to 3.0.2. This vulnerability affects the function axios.post of the file packages/server/src/controllers/evaluations/index.ts of the component Evaluations Endpoint. The manipulation of the argument Host/X-Forwarded-Proto results in server-side request forgery. The attack may be launched remotely. The exploit has been made pub...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90581	New	2.1	LOW		0.002		A vulnerability was determined in cym1102 nginxWebUI up to 4.4.2. This issue affects the function MainController.autoUpdate of the file /adminPage/main/autoUpdate. This manipulation of the argument url causes code injection. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The pull request to fix this issue awaits ac...
CVE-2026-90594	New	2.1	LOW		0.002		A vulnerability was identified in wxiaoqi Spring-Cloud-Platform 3.0.1/3.1.0. This vulnerability affects the function PermissionService.checkUserPermission of the file /rpc/service/PermissionService.java of the component Permission Service. The manipulation leads to missing authorization. Remote exploitation of the attack is possible. The exploit is publicly available and mig...
CVE-2026-90595	New	2.1	LOW		0.002		A security flaw has been discovered in wxiaoqi Spring-Cloud-Platform 1.0/2.2/3.0. This issue affects the function OnlineController.getOnlineInfo of the file aceModules/ace-admin/auth/controller/OnlineController.java. The manipulation results in missing authorization. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks....
CVE-2026-90597	New	2.1	LOW		0.002		A security vulnerability has been detected in itsourcecode Sales and Inventory System 1.0. The affected element is an unknown function of the file /pages/sup_edit1.php. Such manipulation of the argument ID leads to sql injection. The attack may be performed from remote. The exploit has been disclosed publicly and may be used.
CVE-2026-90598	New	2.1	LOW		0.002		A vulnerability was detected in jaygajera17 E-commerce-project-springBoot up to 5e74a46b4b70623d0e4a0c9c4aee3bd1777185d2. The impacted element is the function UserController.updateUser of the file UserController.java. Performing a manipulation of the argument userid results in authorization bypass. It is possible to initiate the attack remotely. The exploit is now public and...
CVE-2026-90599	New	2.1	LOW		0.002		A flaw has been found in Rizwan17 inventory-management-system up to 5e74a46b4b70623d0e4a0c9c4aee3bd1777185d2. This affects an unknown function of the file includes/process.php. Executing a manipulation can lead to cross-site request forgery. It is possible to launch the attack remotely. The exploit has been published and may be used. This product takes the approach of rollin...
CVE-2026-90600	New	2.1	LOW		0.002		A vulnerability has been found in itsourcecode Sales and Inventory System 1.0. This impacts an unknown function of the file /pages/inv_edit1.php. The manipulation of the argument ID leads to sql injection. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-90496	New	2.0	LOW		0.002		A vulnerability was found in Fengoffice Feng Office up to 3.11.13.11. Affected is the function update_system_module_order/update_dimension_order of the file application/controllers/MoreController.class.php of the component Reorder Handlers. Performing a manipulation of the argument modules/dims results in sql injection. The attack may be initiated remotely. The exploit has b...
CVE-2026-90497	New	2.0	LOW		0.002		A vulnerability was determined in Fengoffice Feng Office up to 3.11.13.11. Affected by this vulnerability is the function getTitle of the file application/views/task/add_task.php of the component Task Title Output. Executing a manipulation of the argument og_objects.name can lead to cross site scripting. The attack may be launched remotely. The exploit has been publicly disc...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90502	New	2.0	LOW		0.002		A vulnerability was detected in stilleshan ServerStatus 1.0/2.0. Impacted is an unknown function of the file server/src/main.cpp of the component Stats Generation. Performing a manipulation of the argument custom results in cross site scripting. It is possible to initiate the attack remotely. The exploit is now public and may be used. The vendor was contacted early about thi...
CVE-2026-90572	New	2.0	LOW		0.004		A vulnerability was determined in davenardella snap7 up to 1.4.3. The affected element is the function TSnap7MicroClient::opUpload of the file src/core/s7_micro_client.cpp. Executing a manipulation of the argument DataLen can lead to memory corruption. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized. The project was informed o...
CVE-2026-90573	New	1.9	LOW		0.001		A vulnerability was identified in GPAC up to f1219cde. The impacted element is the function gf_sg_mfurl_del of the file scenegraph/vrml_tools.c of the component MP4Box. The manipulation leads to null pointer dereference. Local access is required to approach this attack. The exploit is publicly available and might be used. This product adopts a rolling release strategy to mai...
CVE-2026-90576	New	1.9	LOW		0.002		A security vulnerability has been detected in GPAC up to f1219cde. Affected is the function gf_node_list_add_child of the file scenegraph/base_scenegraph.c of the component MP4Box. Such manipulation leads to null pointer dereference. The attack can only be performed from a local environment. The exploit has been disclosed publicly and may be used. Upgrading to version abi-16...
CVE-2026-90577	New	1.9	LOW		0.002		A vulnerability was detected in GPAC up to f1219cde. Affected by this vulnerability is the function gf_node_get_field of the file scenegraph/base_scenegraph.c of the component MP4Box. Performing a manipulation results in heap-based buffer overflow. The attack is only possible with local access. The exploit is now public and may be used. Upgrading to version abi-16.23 address...
CVE-2026-90578	New	1.9	LOW		0.002		A flaw has been found in GPAC up to f1219cde. Affected by this issue is the function gf_list_count of the file utils/list.c of the component MP4Box. Executing a manipulation can lead to use after free. The attack is restricted to local execution. The exploit has been published and may be used. Upgrading to version abi-16.23 can resolve this issue. This patch is called 49dee5...
CVE-2025-64059	New	1.8	LOW		0.002		Grav 1.7.50.2 allows admins to enter JavaScript via the Home Page editor. NOTE: the relevance of this for stored XSS is disputed because admins are allowed to modify templates, install plugins, and upload other executable content.
CVE-2026-90503	New	1.8	LOW		0.001		A flaw has been found in Chengdu Qilu Technology Ludashi 6.1026.4715.714. The affected element is the function sub_11008 in the library ComputerZ_x64.sys. Executing a manipulation of the argument PhysicalAddress can lead to information disclosure. The attack needs to be launched locally. The exploit has been published and may be used. The vendor was contacted early about thi...
CVE-2026-90508	New	1.8	LOW		0.001		A security flaw has been discovered in Chengdu Qilu Technology Ludashi 6.1026.4715.714. Affected by this vulnerability is the function MessageNotifyCallback in the library ProtectFilter64.sys of the component Message Dispatch Handler. Performing a manipulation results in missing authorization. Attacking locally is a requirement. The exploit has been released to the public an...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90505	New	1.3	LOW		0.002		A vulnerability was found in vvbnn00 WARP-Clash-API up to c7bf2360073959861219b422e51ae86411051b46. This affects the function doUpdateLicenseKey. The manipulation results in race condition. The attack can be launched remotely. The attack requires a high level of complexity. The exploitability is reported as difficult. The exploit has been made public and could be used. This...
CVE-2026-90506	New	1.3	LOW		0.002		A vulnerability was determined in vvbnn00 WARP-Clash-API up to c7bf2360073959861219b422e51ae86411051b46. This impacts an unknown function of the component Save Account Job. This manipulation causes race condition. The attack may be initiated remotely. The attack's complexity is rated as high. The exploitability is said to be difficult. The exploit has been publicly disclose...
CVE-2026-49030	New						Rejected reason: DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: none. Reason: This candidate was withdrawn by its CNA. Further investigation showed that it was not a security issue. Notes: none.
MAL-2026-16143	New					PyPI:chroma-client	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f0c415e6cd4e653006225dd54672dd79ef076166a2015fa33bbf8f10b789af55) The distribution installs a.pth file that Python auto-executes at interpreter startup on every process using the environment. The.pth file's executable payload is limited to `import os; os.umask(0o022)`, but it embeds co...

Significant updates today - original Published Date retained

None in this window.

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58704	Added to KEV	8.8	HIGH	Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-76460	Added to KEV			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461	Added to KEV			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.
CVE-2026-87886	Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81648	New	10.0	CRIT		0.003		The CryptoPayment Gateway WordPress plugin from 1.2.1 to 1.2.2 does not apply an authorization check on one of its AJAX endpoints, allowing unauthenticated users to invoke administrative operations, including deleting arbitrary files on the server, overwriting the payment gateway configuration and recovering stored wallet credentials in cleartext.
CVE-2026-90562	New	9.2	CRIT		0.004		LangBot before 4.10.11 generates password recovery keys with only 24 bits of entropy and applies no rate limiting to the unauthenticated reset-password endpoint. Remote attackers knowing the administrator email can exhaust the keyspace through concurrent requests to reset the admin password and gain account access.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.